

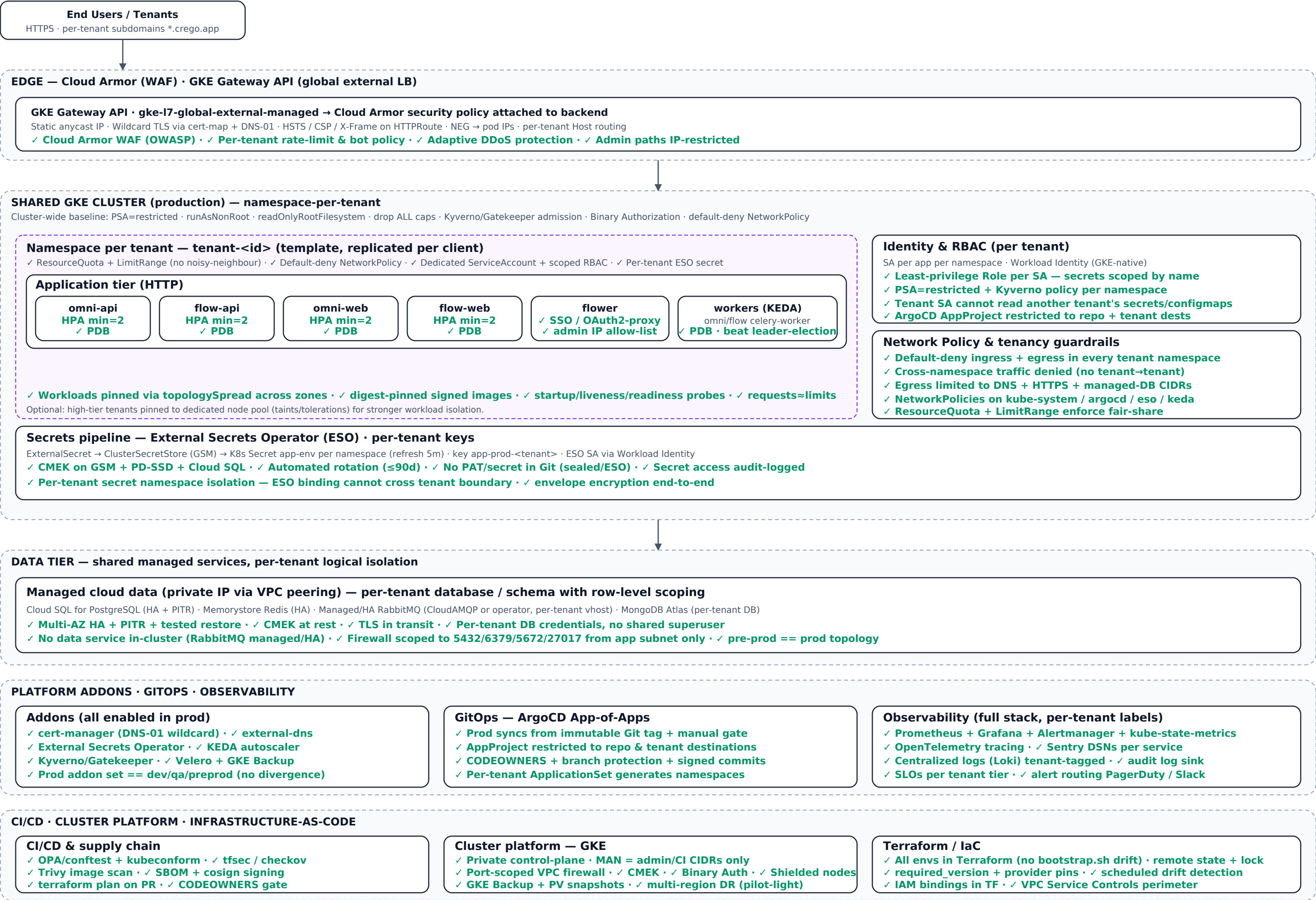
Target Architecture — Multi-Tenant (Crego Shared Cloud)

Production-only · GCP · shared GKE cluster · namespace-per-tenant isolation · shared managed data with per-tenant logical DB · hardened baseline (✓)

TARGET / HARDENED

Status

✓ control implemented & enforced
Isolation: namespace-per-tenant + ResourceQuota + default-deny NetworkPolicy



Target Network — Multi-Tenant (Crego Shared Cloud)

Production-only · GCP project crego-app-prod · shared GKE cluster · namespace-per-tenant · managed data via Service Networking peering

→ inbound HTTPS - - - → egress to internet (NAT) - - - → egress to Google APIs (PGA) → VPC peering (managed data) ✓ configured & enforced

CREGO SHARED PROD CLUSTER · NETWORK

GCP crego-app-prod · region asia-south1 · namespace-per-tenant · PREPROD = identical topology (incl. managed data)

Internet — End users / tenants

Per-tenant subdomains *.crego.app · HTTPS only
Resolves to global anycast IP crego-prod-ip

Operators — kubectl / IAP / ArgoCD UI

✓ **Control-plane PRIVATE endpoint (no public API)**
✓ **Master Authorized Networks = admin + CI CIDRs only · MFA**

443 · global

kube-apiserver 443 (private)

Inbound LB — GKE Gateway API + Cloud Armor

Class gke-l7-global-external-managed · static IP crego-prod-ip · NEG → pod IPs
✓ **Cloud Armor WAF + per-tenant rate-limit + DDoS · HSTS/CSP via**
✓ **TLS via cert-manager DNS-01 wildcard · external-dns manages**

GKE Control-plane (Google-managed VPC)

✓ **enable_private_endpoint=true (PRIVATE)**
CP ↔ nodes peering managed by GKE
✓ **Not reachable from public internet**

VPC: prod-vpc (custom mode, single regional subnet) · Private Google Access ON · Terraform-managed

Subnet: prod-subnet · asia-south1 · Private Google Access: ON

Primary: 10.10.0.0/16 · Pods: 10.20.0.0/14 · Services: 10.24.0.0/20
Service Networking peered range reserved for Cloud SQL + Memorystore

GKE cluster — gke-prod (regional, private nodes)

Nodes: shielded · CMEK disks · auto-repair/upgrade · WI pool crego-app-prod.svc.id.goog
Net Policy: ON (Dataplane-V2) · **Admission:** Kyverno + Binary Authorization

NS tenant-a

apps + workers + flower(SSO)
✓ **ResourceQuota / LimitRange**
✓ **Default-deny NetworkPolicy**
✓ **Dedicated SA + scoped RBAC**
✓ **Per-tenant ESO secret only**
no in-cluster DBs

NS tenant-b ... tenant-n

identical template via ApplicationSet
✓ **Cross-NS traffic denied**
✓ **Tenant SA cannot read peer secrets**
✓ **topologySpread across zones**
✓ **signed/digest-pinned images**
optional dedicated node pool (hi-tier)

✓ **Egress NetworkPolicy: DNS + HTTPS + managed-DB CIDRs only**
✓ **PSA=restricted · readOnlyRootFilesystem · drop ALL caps (all NS)**

Egress paths from pods

→ **Internet:** pod → Cloud NAT → reserved NAT IP
→ **Google APIs:** pod → Private Google Access → googleapis.com
→ **Managed data:** pod → VPC peering → Cloud SQL / Memorystore (private IP)
✓ **Tenant DB creds scoped — pod reaches only its own logical DB**
✓ **Default-deny NetworkPolicy — only declared flows allowed**
External MongoDB (if used) egress via Cloud NAT with TLS

Service Networking (managed data)

VPC peering servicenetworking · reserved range

Cloud SQL — Postgres (HA)

Private IP · HA + PITR ON · CMEK
✓ **Per-tenant DB · no shared superuser**

Memorystore — Redis (HA)

Private peering · same region · CMEK
✓ **Managed/HA RabbitMQ (per-tenant vhost)**
✓ **MongoDB Atlas — per-tenant DB**

Cloud Router + Cloud NAT

✓ **RESERVED static NAT IP — stable egress**
Partner IP allow-listing stays valid
✓ **NAT logging enabled**

VPC firewall rules (least-privilege, Terraform-managed)

✓ **Port-scoped: TCP 5432 (SQL) · 6379 (Redis) · 5672/15672 (Rabbit) · 27017 (Mongo) · 53 · 443 only**
✓ **Implicit deny ingress from internet · ✓ Cloud SQL/Memorystore reachable only from app subnet (no lateral movement)**
✓ **Defence-in-depth: VPC firewall + K8s NetworkPolicy · explicit egress allow-list**

Prod addon parity (no divergence)

✓ **addons/prod-gcp/ includes cert-manager + external-dns + KEDA + ESO (same as dev/qa/preprod)**
✓ **Tenant subdomain DNS auto-managed by external-dns · ✓ TLS via DNS-01 wildcard (unified cert flow)**
✓ **PREPROD uses managed Cloud SQL/Memorystore too — valid release gate**

Google APIs & managed services (Private Google Access / VPC peering)

Secret Manager: project crego-app-prod · per-tenant key app-prod-<tenant> — ESO via WI · CMEK · rotation ≤90d

Cloud DNS: zone crego.app — records auto-managed by external-dns

Artifact Registry: signed-image pulls · **Cloud Logging:** node SA writes logs/metrics

✓ **CMEK on GSM/PD/Cloud SQL · ✓ VPC Service Controls perimeter · ✓ K8s API audit log sink (BQ/GCS) → SIEM**
✓ **Cloud SQL cross-region read-replica enabled for DR (pilot-light secondary region)**